

PR #32 — Self-contained parser worker: packaging, licences, integrity gate

Base: `integrate/evidence-search` · Head: `packaging/self-contained-worker`

What this delivers

The forked upload parser loads `pdfjs-dist`, `mammoth` and `mailparser` dynamically in a child process, so the build tracer never sees them and the deployed standalone package previously risked shipping without them. Their inclusion used to depend on `serverExternalPackages / outputFileTracingIncludes` in `next.config.js`, which is platform-managed and reverts on every checkpoint. This PR removes that dependency by pre-bundling the worker and its three heavy dependencies into a single self-contained ES module committed at `public/parser/worker.mjs`, which the launcher forks at runtime. Because the deploy step unconditionally copies `public/` into the standalone artifact, the worker ships regardless of `next.config.js`.

Complete diff (by area)

- `lib/workspaces/parser.ts` — forks the committed `public/parser/worker.mjs` via a runtime-assembled path (so Turbopack does not try to resolve it as a static import). Subprocess isolation, restricted environment, 128 MiB heap cap and 20 s timeout are unchanged.
- `lib/workspaces/parse-file.mjs` — heavy dependencies loaded via dynamic `import()` inside their branches so esbuild can inline them; PDF branch imports the `pdfjs` worker module for its side effect.
- `public/parser/worker.mjs` — the committed self-contained bundle (esbuild 0.28.2; `pdfjs-dist` 6.3.289, `mammoth` 1.12.2, `mailparser` 3.9.23 inlined). sha256 `c39f2bc8...`
- `scripts/parser-worker.config.mjs`, `scripts/build-parser-worker.mjs`, `scripts/check-parser-worker.mjs` — shared esbuild config, the bundler (`yarn build:worker`), and the integrity checker (`yarn check:worker`).
- `public/parser/worker.LICENSES.txt`, `public/parser/worker.manifest.json` — third-party attribution and the integrity manifest (hashes + pinned versions).
- `package.json` — esbuild pinned as an explicit dev dependency at `0.28.2`.
- `ci/yarn.lock` — a portable, committed lockfile (a copy of the platform store's fully-resolved lockfile, carrying no machine-specific paths) used by the CI verification route; it does not change the platform-managed store.
- `.github/workflows/parser-worker-integrity.yml` — a CI workflow that runs `yarn check:worker` from a fresh, immutable install using `ci/yarn.lock`. Adding this file does not by itself make the check required; a maintainer must enable it as a required status check in branch protection.

Review fixes included

- **esbuild pinned and a portable lockfile committed.** esbuild was only transitive and loosely constrained (`~0.25.0 / >=0.12 <1`) while the byte-identical bundle needs exactly `0.28.2`; it is now an explicit pinned dev dependency. The repo `yarn.lock` is a git-tracked symlink into the platform store and cannot carry a project-local lock, so a portable copy of the fully-resolved lockfile is committed at `ci/yarn.lock` (no machine-specific paths; pins esbuild `0.28.2`, `pdfjs-dist`

6.3.289, mammoth 1.12.2, mailparser 3.9.23 and the rest of the graph). The CI route installs from it with `yarn install --immutable`, so no new versions are silently resolved.

- **Integrity check runs in CI (not automatically required).** `yarn check:worker` runs in the `parser-worker-integrity.yml` workflow on pull requests into `integrate/evidence-search` and `main` (and pushes to them). Adding the workflow does NOT make it a required check — a maintainer must add the check named `Parser worker integrity / check-worker` in Settings → Branches for it to block merges. The workflow has no `paths:` filter, so it always runs and is therefore compatible with being marked required. It replaces the platform lockfile symlink with the committed `ci/yarn.lock` and runs `yarn install --immutable`, so the fresh install cannot silently resolve new versions; a green run proves the bundle reproduces off-platform. It is intentionally NOT wired into `yarn run build`, so drift never aborts a production deploy.
- **Licence attribution corrected.** The generator previously skipped packages whose `exports` map blocks `<pkg>/package.json` resolution. It now resolves the actual package directory for every entry in esbuild's input graph (including nested versions), inspects licence filenames case-insensitively, collects applicable `NOTICE` files, and throws if any inlined package cannot be attributed. Attribution now covers **53 inlined packages: 51 attributed from bundled licence/NOTICE files, and 2 reconstructed from a canonical SPDX template** — `dingbat-to-unicode@1.0.1` (BSD-2-Clause) and `isarray@1.0.0` (MIT) — because those two ship no standalone licence file. Both reconstructions are clearly labelled non-verbatim in `worker.LICENSES.txt`, and neither the file header nor the manifest claims complete verbatim attribution while they remain reconstructed.
- **Worker bytes made reproducible off-platform.** esbuild follows the workspace `node_modules` symlink into the platform store and baked that absolute store path into the bundle's module keys and `// path` comments, so a fresh install with real `node_modules` produced a non-byte-identical worker. The build now sets `preserveSymlinks: true`, emitting stable `node_modules/<pkg>/...` paths from both the platform (symlinked) build and a genuinely fresh install. This changed `worker.mjs` from sha256 `ac385816...` to `c39f2bc8...` — a path-normalisation change only, with no code or dependency change — and removes the leaked host path from the committed bundle.

Validation

- Private + PDF suites: 28 pass / 0 fail. Evidence regression: 25 pass / 0 fail.
- `tsc --noEmit`: clean. `prisma validate`: valid. `yarn check:worker`: green (byte-identical rebuild).
- Reproducibility: a genuinely fresh `yarn install --immutable` from `ci/yarn.lock` (real `node_modules`, isolated cache) left the lockfile unmutated and produced a byte-identical `worker.mjs` (`c39f2bc8...`), confirming off-platform reproducibility.
- Faithful standalone build (platform packaging with the unmodified platform `next.config.js`): exit 0; `worker.mjs` present in `.build/standalone/app/public/parser/`; `pdfjs-dist` / `mammoth` / `mail-parser` absent from the standalone `node_modules`; no worker-resolution errors.

Limitations

- `public/parser/worker.mjs` is web-accessible (e.g. `/parser/worker.mjs`); it contains only our own non-secret parsing code and the child process receives no application secrets.
- Fixture tests use PGlite and an injected actor/scanner stub; they do not prove production authentication, ClamAV, hosted database concurrency, browser UX or deployment isolation. This PR is a packaging/attribution change and enables no confidential-use feature — all private-workspace flags remain disabled.

Rollback

Revert the merge commit. The worker is a committed static asset with no migration and no runtime dependency change, so reverting restores the previous behaviour with no data or schema impact. No production flag or secret is touched by this PR.